ONE-PAGE BRIEF

Post-quantum cryptography review: foundry @ 7f0a409a5c20

Client: Foundry (Paradigm) — public repository (passive review) · Source: github.com/foundry-rs/foundry, commit `7f0a409a5c20` · Reviewed: 2026-10-28 12:26 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 4 of 4

post-quantum by default in the critical paths

FINDINGS

0 Critical **2** High **3** Medium **10** Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 3 − 8 = 5 → **too late**

Signatures: 5 + 3 − 8 = 0 → **tight**

Next step: Keep the inventory current and review new code paths before release.

WHAT MATTERS MOST

High QSI-2026-04469	**quick-xml 0.39.4 is affected by RUSTSEC-2026-0194** What to do: Upgrade to a fixed version (0.41.0).
High QSI-2026-04470	**quick-xml 0.39.4 is affected by RUSTSEC-2026-0195** What to do: Upgrade to a fixed version (0.41.0).
Medium QSI-2026-04456	**TLS without a post-quantum key exchange: rustls with the ring crypto provider** preliminary What to do: Build rustls with the aws-lc-rs provider (rustls::crypto::aws_lc_rs) and the prefer-post-quantum feature, which puts X25519MLKEM768 first.
Medium QSI-2026-04462	**block-buffer 0.9.0 is affected by GHSA-qwgh-2vcv-g2f7** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).

11 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium channel key exchange (TLS, Noise, handshakes)	TLS ECDHE	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)
Low transaction and message signing	ECDSA, BLS12-381	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Low authentication and identity (certificates, tokens, device attestation)	ECDSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Low role not determined	BLS12-381, ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 7; each needs checking against the code.

Static review of source code and manifests; files analysed: 761. No requests were sent to the owner's systems.

Full report, content SHA-256: `37dc71482c0ac19cdfddf6850b40a433a909c798e26a1f8725c5dfb354258319`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.